

目录

第 1 章 信息安全概论	1
1.1 网络空间安全定义	1
1.2 信息安全及其基本目标	1
1.3 网络安全四大基础板块	1
第 1 章 重点	1
第 2 章 信息安全风险管理	2
2.1 资产的分类	2
2.2 脆弱性	2
2.3 风险的定义	2
2.4 风险评估的定义	2
2.5 风险信息是动态变化的	2
2.6 网络空间安全风险术语之间的关系	3
第 2 章 重点	3
第 3 章 信息与信息安全保障	4
3.1 PDR 和 PPDR 模型	4
3.2 IATF	4
第 3 章 重点	5
第 4 章 信息安全技术	6
4.1 网络空间安全的总需求	6
4.2 网络空间安全的最终目标	6
4.3 管理与技术并重	6
4.4 数字签名的特性	6
4.5 抗抵赖面临的威胁	6
第 4 章 重点	6
第 5 章 鉴别技术	8
5.1 鉴别需求和目的	8
5.2 对身份鉴别系统的要求	8
5.3 鉴别技术分类	8
5.4 对抗重放	8
5.4.1 序列号	8
5.4.2 时间戳	8
5.4.3 验证者发送随机值	8
5.5 对付线路窃听的措施	9
5.6 对付危及验证者的措施	9
5.7 对付窃听及危及验证者的措施	9
5.8 质询一应答	9
第 5 章 重点	10
第 6 章 访问控制	11

6.1 访问控制的作用	11
6.2 访问控制表 ACL	11
6.3 能力表	11
6.4 自主访问控制 DAC	11
6.5 强制访问控制 MAC	11
6.6 RBAC 模型 [5]	12
第 6 章 重点	12
第 7 章 防火墙	13
7.1 防火墙定义	13
7.2 包过滤防火墙	13
7.3 完全内容检测防火墙	13
7.4 被屏蔽子网 (DMZ)	13
7.5 NAT	14
7.6 MAP(地址/端口映射)	14
7.7 企业防火墙的典型部署	14
7.8 衡量防火墙性能的五大指标	14
7.9 WAF	14
第 7 章 重点	14
第 8 章 入侵检测技术	16
8.1 什么是入侵, 什么是入侵检测, 什么是入侵检测系统	16
8.2 入侵检测系统的功能	16
8.3 通用入侵检测模型 (Denning 模型)	16
8.4 主机入侵检测系统	16
8.5 网络入侵检测系统	16
8.6 入侵检测系统的典型部署及问题	16
8.7 IDS 的两个指标	17
第 8 章 重点	17
第 9 章 其他安全技术: GAP IPS NAC	18
9.1 什么是 IPS	18
9.2 IPS 主要功能	18
9.3 IPS 能够解决的安全问题	18
9.4 什么是网闸	18
9.5 国家保密局限定的安全隔离网闸使用环境	18
9.6 什么是网络准入控制 NAC	18
9.7 NAC 主要功能	19
9.8 网络准入控制基本流程	19
第 9 章 重点	19
第 10 章 VPN IPSec SSL	20
10.1 IPSec 协议	20
10.1.1 AH 协议	20
10.1.2 ESP 协议	20
10.2 IPSec 封装模式	20

10.2.1 传输模式	20
10.2.2 隧道模式	20
10.3 VPN 通道的建立方式	21
第 10 章 重点	21
参考文献	22

第 1 章 信息安全概论

1.1 网络空间安全定义

定义 1.1 (网络空间安全)

网络空间安全是关键信息基础设施保护 (Critical Information Infrastructure Protection, CIIP) 的必要组成部分, 同时, 对关键基础设施服务的充分保护也有助于满足基础安全需求 (即关键基础设施的安全性、可靠性和可用性), 进一步实现网络空间安全的目标。



1.2 信息安全及其基本目标

信息本身的机密性、完整性和可用性的保持。

- 机密性: 防止未经授权使用信息
- 完整性: 防止对信息的非法修改和破坏
- 可用性: 确保及时可靠地使用信息。

1.3 网络安全四大基础板块

- 信息安全
- 应用安全
- 网络安全
- 因特网安全

📖 第 1 章 重点 📖

1. 什么是网络空间安全?

第2章 信息安全风险管理

2.1 资产的分类

资产以多种形式存在：

- 物理的、逻辑的
- 硬件的、软件的
- 有形的、无形的
- 静态的、动态的
- 技术的、管理的

定义 2.1 (资产)

资产是任何对组织有价值的东西，是要保护的对象。



2.2 脆弱性

脆弱性本身并不对资产构成危害，但是在一定条件得到满足时，脆弱性会被威胁源利用恰当的威胁方式对信息资产造成危害。

2.3 风险的定义

有两个定义一个是国标的，一个是简略的。

定义 2.2 (风险)

人为或自然的威胁利用信息系统及其管理体系中存在的脆弱性导致安全事件的发生及其对组织造成的影响。



定义 2.3 (风险)

指威胁源采用恰当的威胁方式利用脆弱性造成不良后果



2.4 风险评估的定义

定义 2.4 (风险评估)

从风险管理角度，运用科学的方法和手段，系统地分析信息系统所面临的威胁及其存在的脆弱性，评估安全事件一旦发生可能造成的危害程度，提出有针对性的抵御威胁的防护对策和整改措施；为防范和化解网络空间安全风险，将风险控制在可接受的水平，从而为最大限度地保障网络空间安全提供科学依据。



2.5 风险信息是动态变化的

信息系统的安全风险信息是动态变化的，只有动态的信息安全评估才能发现和跟踪最新的安全风险。

2.6 网络空间安全风险术语之间的关系

网络空间安全风险术语-之间的关系

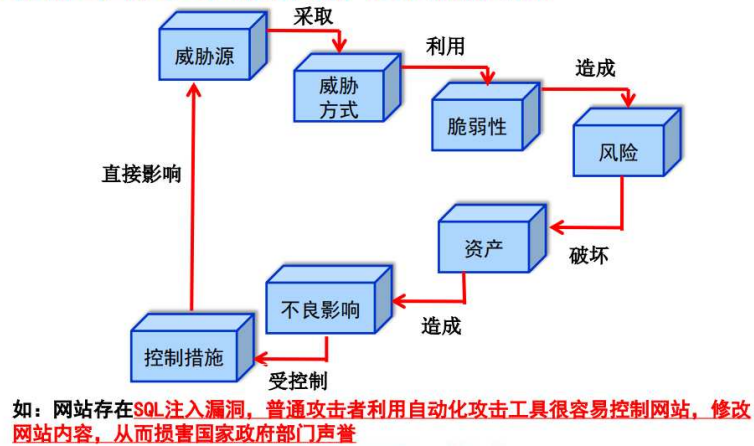


图 2.1: 网络空间安全风险术语之间的关系

第 2 章 重点

1. 网络空间安全资产的分类（能判断哪个是资产）
2. WannaCry 是由哪一个风险引起的（风险分析）
3. 什么是风险？
4. 什么是风险评估？

第3章 信息与信息安全保障

3.1 PDR 和 PPDR 模型

最开始提出了一个基于时间的 PDR 模型，主要有三个部分：保护、检测、响应，即采用一切可能的措施来保护网络；同时通过检测来了解和评估网络和安全系统的安全状态，为响应提供依据；通过应急响应机制依据评估来调整。但是 PDR 模型任何防护措施都是基于时间的，难以适应网络安全环境的快速变化

命题 3.1 (PDR)

PDR 定义了防护时间 Pt (攻击者发起攻击时，保护系统不被攻破的时间)、检测时间 Dt (从发起攻击到检测到攻击的时间) 和响应时间 Rt (从发现攻击到做出有效响应的的时间)3 个概念，并给出了评定系统安全的计算方式，当 $Pt > Dt + Rt$ 时，即认为系统是安全的，也就是说，如果在攻击者攻破系统之前发现并阻止了攻击的行为，那么系统就是安全的。[7]（这三个指标很难被定义，所以个人觉得他就是一个理论性的东西，所以才提出一个 PPDR 模型）

PPDR 的核心就是第一个 P，即策略。所有的防护、检测、响应都是依据安全策略实施的。

3.2 IATF

IATF 关注四个信息安全保障领域：特别注意本地计算环境，推荐使用的基于主机的入侵检测系统的部署

1. 本地计算环境

- 使用安全的操作系统
- 使用安全的应用程序
- 主机入侵检测
- 防病毒系统
- 主机脆弱性扫描
- 文件完整性保护

课件上给出的是这几个，其实除了前两个，后面几个都属于 Host-Based Monitoring[3]

Host-Based Monitoring. Host-based monitoring technologies include detection and eradication of malicious software like viruses; detection of software changes; checking of configuration changes; and audit, audit reduction, and audit report generation. Monitoring mechanisms include tools run by users, such as antivirus software, and tools managed by system administrators. For example, administrators use network and host-based vulnerability analysis tools to verify that vendor patches are installed, detect weak user passwords, and monitor for excessive use of user access privileges. Virus protection software should be used within local computing environments.

图 3.1: IATF 中在保护本地计算中提到的 Host-Based Monitoring

2. 区域边界

- 病毒、恶意代码防御
- 防火墙
- 入侵检测
- 远程访问
- 多级别安全

3. 网络和基础设施

- 骨干网可用性
- 无线网络安全框架
- 系统高度互联和虚拟专用网

4. 支撑性基础设施

- 密钥管理
- 优先权管理
- 证书管理
- 审计、配置
- 信息调查、收集

第3章 重点

1. PPDR 模型核心
2. IATF 保护本地计算环境用什么手段

第 4 章 信息安全技术

4.1 网络空间安全的总需求

物理安全、网络安全、信息内容安全、应用系统安全、安全管理的总和

4.2 网络空间安全的最终目标

确保信息的机密性、完整性、可用性、可控性、抗抵赖性，以及信息系统主体对信息资源的控制

4.3 管理与技术并重

管理是信息系统安全的灵魂。信息系统安全的管理体系由法律管理、制度管理和培训管理三个部分组成。管理与技术是并重关系，而不是三分技术、七分管理

4.4 数字签名的特性

- 不可伪造
- 抗抵赖
- 保证消息完整（使用哈希函数）

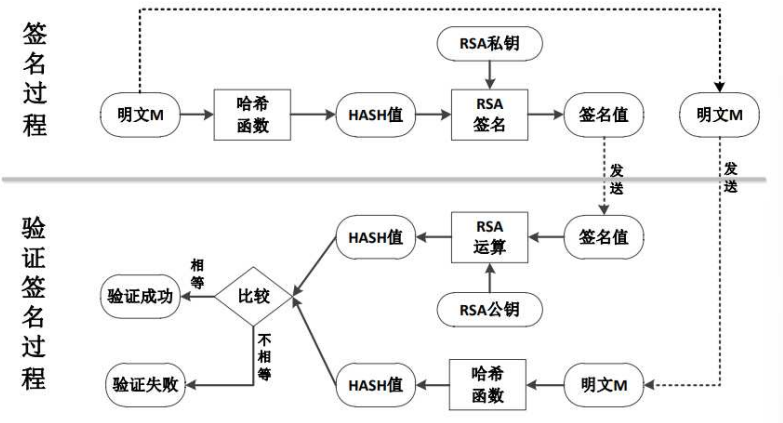


图 4.1: 基于 RSA 数字签名流程

4.5 抗抵赖面临的威胁

- 密钥泄露
- 泄露证据
- 伪造证据

第 4 章 重点

1. 五个安全服务是什么？
2. 八个机制是什么？

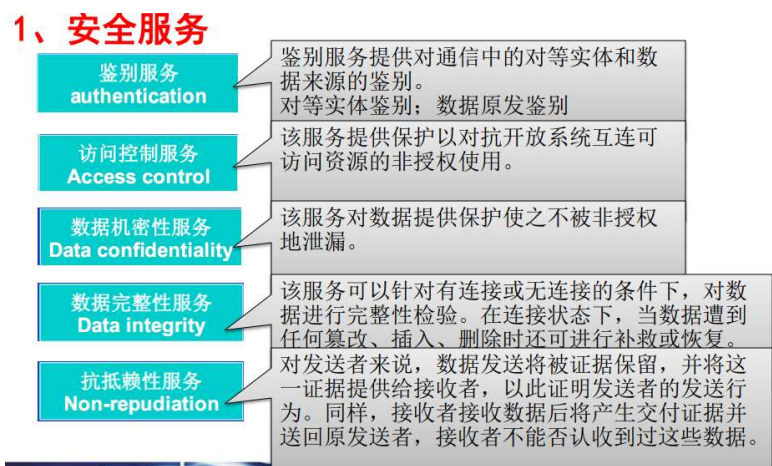


图 4.2: 五个安全服务

开放系统互连安全体系结构

2. 安全机制

八种基本的安全机制	其他安全机制
① 加密	① 可信功能模块（可信软硬件系统部件）
② 数字签名机制	② 安全标记
③ 访问控制机制	③ 事件检测
④ 数据完整性机制	④ 安全审计跟踪
⑤ 鉴别交换机制	⑤ 安全恢复
⑥ 通信业务流填充机制	
⑦ 路由选择控制机制	
⑧ 公证机制	

图 4.3: 五个安全服务

第5章 鉴别技术

5.1 鉴别需求和目的

性质 证明某一个成员声称的主体就是他自己。

结论 使别的成员（验证者）获得对声称者所声称的事实的信任。

5.2 对身份鉴别系统的要求

- 验证者正确识别合法申请者的概率极大化
- 不具有可传递性
- 攻击者伪装成申请者欺骗验证者成功的概率要小到可以忽略的程度
- 计算有效性
- 通信有效性
- 秘密参数能安全存储

四个拓展要求：

- 交互识别
- 第三方的实时参与
- 第三方的可信赖性
- 可证明的安全性

5.3 鉴别技术分类

- 0级鉴别（无保护）
- 1级鉴别（抗泄露保护）
- 2级鉴别（抗泄露和对不同验证者重放的保护）
- 3级鉴别（抗泄露和对同一验证者重放的保护）
- 4级鉴别（抗泄露和对相同/不同验证者重放的保护）

5.4 对抗重放

5.4.1 序列号

双方记住使用过的随机数，如果报文中有以前使用过的随机数，认为是重放攻击。缺点显而易见，需要很大的存储空间来存储使用过的随机数

5.4.2 时间戳

缺点就是需要同步时间

5.4.3 验证者发送随机值

客户端请求服务器

服务器先成一个随机数，发给客户端，每次随机数都有变化

客户端带上这个随机数，访问服务器
服务器验证如果随机数相同，不是重放攻击

5.5 对付线路窃听的措施

验证者持有 q ，声称者持有 p' ，而 p' 进行一种单向运算时得到的 q' 与 q 相同，此时就将发送的信息，即图中的 id ，加上 $hash$ 过的认证标识一起传到验证者；验证者取出 id ，加上自己所持有的 q ，与原始消息进行比较从而防止窃听。

其实这就是最简单的登录功能的验证方式，其脆弱性体现在可能造成撞库攻击。解决办法就是在声称者这一侧加盐

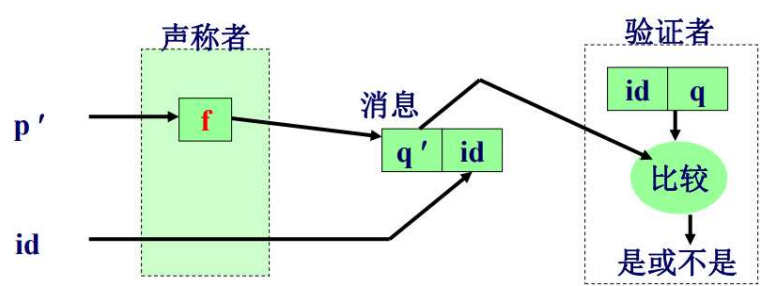


图 5.1: 对付线路窃听的措施

5.6 对付危及验证者的措施

在验证者这一侧加盐

5.7 对付窃听及危及验证者的措施

在两侧都加盐

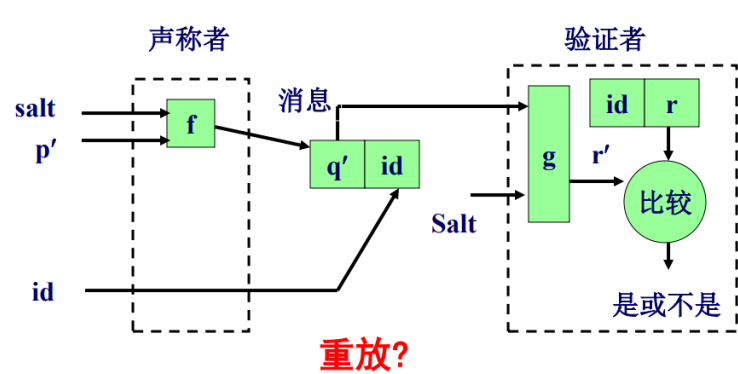


图 5.2: 对付窃听及危及验证者的措施

5.8 质询—应答

可以理解为声称者向验证者要一个盐值，然后将得到的盐和自己的 ID 混合进行 $hash$ ，再把值传给验证者，验证者就可以验证自己手里的信息是否与声称者一样

质询—响应的身份鉴别，其安全性取决于散列函数的安全性，但由于是单向鉴别，还存在着验证者的假冒和重放攻击。这可以通过双向鉴别或时间戳来解决。

第5章 重点

1. 质询-应答机制属于第几级
2. 在给出的鉴别方案中，哪些方案较为安全
3. 对身份鉴别的要求（*）+ 四个扩展要求

第 6 章 访问控制

6.1 访问控制的作用

作用 防止未授权地访问。

很简单的一句话，这里面还涉及水平越权和垂直越权，具体可以先参考 OWASP TOP10[6]，就不展开了

作用 保护 CIA

6.2 访问控制表 ACL

也就是对每个客体（也就是资源），维护一张包含主体信息的链表，这个主体信息包含主体对这个客体的访问权限。所以得到一个客体所有的访问权限很容易。但是获得一个主体的所有访问权限很困难，因为这个表是分散的

6.3 能力表

也就是和 ACL 对立的，每个用户都有一个链表，每个节点就是一个客体资源，包含对它的访问权限

6.4 自主访问控制 DAC

允许客体的所有者决定各个主体对这个客体的访问权限 (可以参考 Linux)

优点：灵活性高

缺点：信息在传递过程中其访问权限关系会被改变

注 解释一下信息在传递过程中其访问权限关系会被改变：假如 B 对 C 有访问权限，而 A 对 C 没有访问权限但对 B 有访问权限，此时 A 就可以通过 B 来访问 C。可以类比为 SSRF

6.5 强制访问控制 MAC

主体对客体的所有访问请求按照强制访问控制策略进行控制，客体的属主无权控制客体的访问权限，以防止对信息的非法和越权访问

也就是主体和客体被分配一个安全属性，如绝密、秘密……

MAC 中有两个定义：下读/上写、上读/下写，但是只给了定义不太好理解。

这里我就解释一下，参考知乎的一篇文章 [2]：

这里的两个定义其实就是两个模型，即 ‘Bell-LaPadula 模型’ 和 ‘Biba 模型’。这两个模型一个是保护机密性但是不保护完整性，另一个保护完整性、不保护完整性。

注

- 下读/上写（保护机密性）：我们先站在高密级向下看。首先我的数据是 ** 高密级 ** 为了保证机密性肯定不能向低密级的用户泄露，所以不能下写。但是我可以读取低密级的信息，因为我的咖位足够高，我不会泄露秘密（**下读**）；然后站在低密级向上看。我的级别不够高，所以肯定不能得到上面的信息，就不能上读。但是我的秘密肯定不能向下写，但可以向上去写来保证我的秘密的机密性（**上写**）。
- 上读/下写（保护完整性）：完整性 1，2，3，4 级，1 级是最高完整性，也就是说我是最高指令，比如是董事会最高决议，它并不需要保密，谁都能看（**上读**），但任何人不得破坏我的完整性，不能修改我的决议，只

有我 1 级的人才能修改。所以 2 级的人不可以写我 1 级的内容。但 2 级可以读我 1 级的内容，来生成 2 级的信息(下写)。此时，数据只能由高向低流，而禁止从低向高流。

6.6 RBAC 模型 [5]

RBAC 的基本思想是根据用户所担任的角色来决定用户在系统中的访问权限。

注意的是：许可 = 操作 + 客体，角色对应这许可，这是一个细粒度的划分

RBAC 模型的特点：

- 便于授权管理，如系统管理员需要修改系统设置等内容时，必须有几个不同角色的用户到场方能操作，增强了安全
- 便于处理工作分级，如文件等资源分级管理
- 利用安全约束，容易实现各种安全策略，如最小特权、职责分离等
- 便于任务分担，不同角色完成不同的任务

第 6 章 重点

1. DAC 与 MAC 定义和关系
2. 在 MAC 保护数据
3. RDAC 的关键
4. 什么是授权访问？什么是非授权访问？
5. RBAC 模型

第 7 章 防火墙

7.1 防火墙定义

定义 7.1 (防火墙)

一种高级访问控制设备，置于不同网络安全域之间，它通过相关的安全策略来控制（允许、拒绝、监视、记录）进出网络的访问行为。



7.2 包过滤防火墙

在网络层检查数据包
简单的拒绝接收模型
无法识别更高层协议

优点：只对 IP 地址、TCP/UDP 协议和端口进行分析，规则简单，处理速度较快，易于配置、对用户透明

缺点：检查和过滤器只在网络层、安全性薄弱、静态策略可能成为漏洞

7.3 完全内容检测防火墙

完全内容检测技术防火墙综合状态检测与应用代理技术，并在此基础上进一步基于多层检测架构，把防病毒、内容过滤、应用识别等功能整合到防火墙里，其中还包括 IPS 功能，多单元融为一体，在网络界面对应用层扫描，把防病毒、内容过滤与防火墙结合起来，这体现了网络与信息安全的新思路，(因此也被称为“下一代防火墙技术”)。它在网络边界实施 OSI 第七层的内容扫描，实现了实时在网络边缘部署病毒防护、内容过滤等应用层服务措施。完全内容检测技术防火墙可以检查整个数据包内容，根据需要建立连接状态表，网络层保护强，应用层控制细等优点，但由于功能集成度高，对产品硬件的要求比较高。[4]

7.4 被屏蔽子网 (DMZ)

使用两台防火墙分别作为外部防火墙和内部防火墙，在两台防火墙之间形成了一个非军事区网段。

- 外部流量允许进入 DMZ 网段
- 内部流量允许进入 DMZ 网络并通过 DMZ 网段流出至外部网络
- 外部网络的流量不允许进入直接进入内部网络

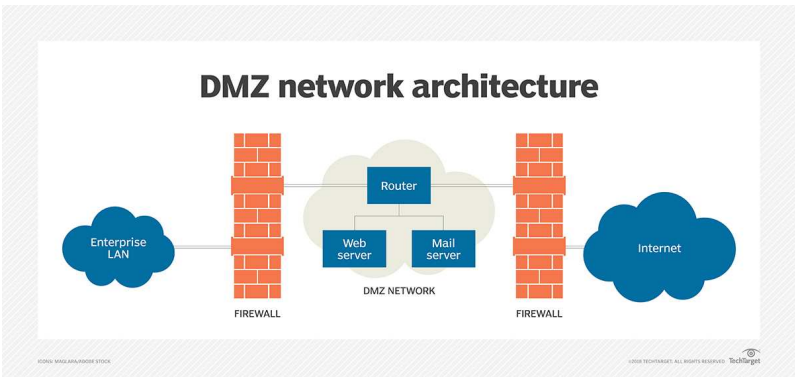


图 7.1: DMZ 架构

7.5 NAT

就是提供一个类似路由器里面 NAT 的功能来隐藏内部的网络结构。通过 IP 的转换表来更改 IP 包头中的目的 IP 地址

7.6 MAP(地址/端口映射)

- 公开服务器可以使用私有地址
- 隐藏内部网络的结构
- 外网通过访问某个公网 IP 的地址和端口，防火墙 MAP 到特定的 IP 和端口

7.7 企业防火墙的典型部署

这是最为普通的企业环境防火墙部署案例。利用防火墙将网络分为三个安全区域，企业内部网络，外部网络和服务器专网 (DMZ 区)。

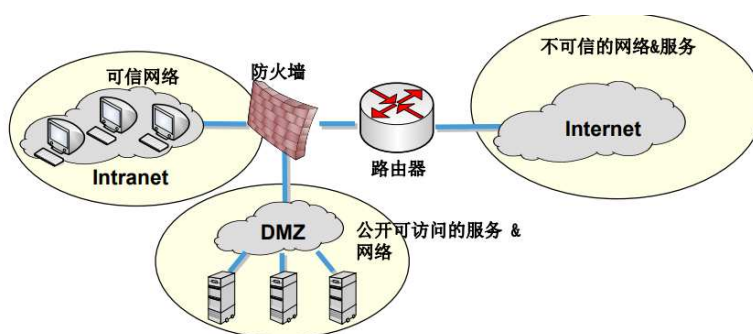


图 7.2: 企业防火墙的典型部署

7.8 衡量防火墙性能的五大指标

- 吞吐量：该指标直接影响网络的性能，吞吐量
- 时延：入口处输入帧最后 1 个比特到达至出口处输出帧的第 1 个比特输出所用的时间间隔
- 丢包率：在稳态负载下，应由网络设备传输，但由于资源缺乏而被丢弃的帧的百分比
- 背靠背：从空闲状态开始，以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧，当出现第一个帧丢失时，发送的帧数
- 并发连结数：并发连接数是指穿越防火墙的主机之间或主机与防火墙之间能同时建立的最大连接数

7.9 WAF

对 Web 特有入侵方式的加强防护，如 DDOS 防护、SQL 注入、XML 注入、XSS 等。由于重点是防 SQL 注入，也有人称为 SQL 防火墙。

由于是应用层而非网络层的入侵，从技术角度都应该称为 Web IPS，而不是 Web 防火墙。

第 7 章 重点

1. 在两个网段之间的保护措施，对于边界保护

2. 防火墙的基本功能是?
3. 如何构建基于企业级保护的防火墙的部署方式, 包括防火墙的功能。

第8章 入侵检测技术

8.1 什么是入侵，什么是入侵检测，什么是入侵检测系统

- **入侵**：是指在非法或未经授权的情况下，试图存取或处理系统或网络中的信息，或破坏系统或网络正常运行，致使系统或网络的机密性、完整性和可用性受到破坏的故意行为。
- **入侵检测**：是对入侵行为的发觉。它通过计算机网络或计算机系统的关键点采集信息并进行分析，从中发现网络或系统中是否有违反安全策略的行为和被攻击的迹象。
- **入侵检测系统**：是指实现入侵检测功能的软件和硬件的集合

8.2 入侵检测系统的功能

- 自动检测入侵行为
- 监视网络流量 (NIDS) 和主机中的操作 (HIDS)
- 分析入侵行为: 基于特征或者基于异常
- 按预定的规则做出响应

8.3 通用入侵检测模型 (Denning 模型)

Denning 模型实际上是一个基于规则的模式匹配系统, 未包含已知系统漏洞或攻击方法方面的知识

8.4 主机入侵检测系统

基于主机的入侵检测系统是以代理软件的形式安装在每台主机或服务器上, 以监测主机上的各种活动 (最近的深信服的那个新闻就可能就是因为公司部署了这个)

按照检测对象的不同, 基于主机的入侵检测系统可以分为两类:

- 网络连接检测
- 主机文件检测

8.5 网络入侵检测系统

- 以混杂模式接入网络
- 感应器可部署在网络的关键位置
- 将日志/告警信息发送至位于企业防火墙内部的服务器

缺点: 无法分析加密的数据、从网络流量可以推断发生了什么, 但不能判断结果、对全交换网络需要配置交换机端口镜像、对于带宽的要求较高

8.6 入侵检测系统的典型部署及问题

以旁路的方式接入到网络中, 且部署在需要的关键位置

第 9 章 其他安全技术：GAP IPS NAC

9.1 什么是 IPS

一言蔽之就是 IDS+ 防火墙。具体说就是可以检测入侵行为的发送，并通过一定的响应方式终止入侵行为的发生和发展

9.2 IPS 主要功能

- 识别对网络和主机的恶意攻击，并实时进行阻断
- 向管理控制台发送日志信息
- 集成病毒过滤、带宽管理和 URL 过滤等功能

9.3 IPS 能够解决的安全问题

- 阻拦已知攻击
- 为已知漏洞提供虚拟补丁（补丁点前移）
- 速率或流量控制
- 行为管理

注 虚拟补丁通过实施多层安全策略和规则来防止和拦截攻击者通过网络利用漏洞，从而在网络层面，而不是主机层面，提供针对该漏洞的安全覆盖。[1]

9.4 什么是网闸

网闸是在两个不同安全域之间，通过协议转换的手段，以信息摆渡的方式实现数据交换，且只有被系统明确要求传输的信息才可以通过。其信息流一般为通用应用服务。

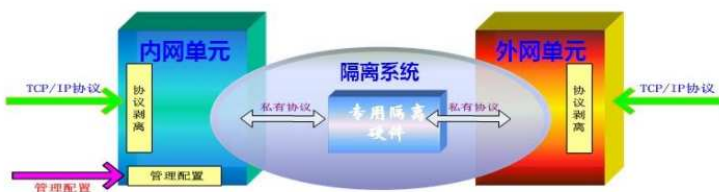


图 9.1: 网闸

通过网闸时，会切断两端的协议连接，将数据包分解为静态数据，然后对数据进行审查等操作，然后通过私有协议再流入内部单元

9.5 国家保密局限定的安全隔离网闸使用环境

9.6 什么是网络准入控制 NAC

NAC 网络安全解决方案从用户角度考虑内部网络安全，通过对接入用户进行安全控制，提供“端到端”的安全保证。借助于 NAC 方案，实现“只有合法的用户、安全的终端才可以接入网络”，隔离非法、不安全的用户和终端，或者仅允许他们访问受限的资源。以此来提升整个网络的安全防护能力。

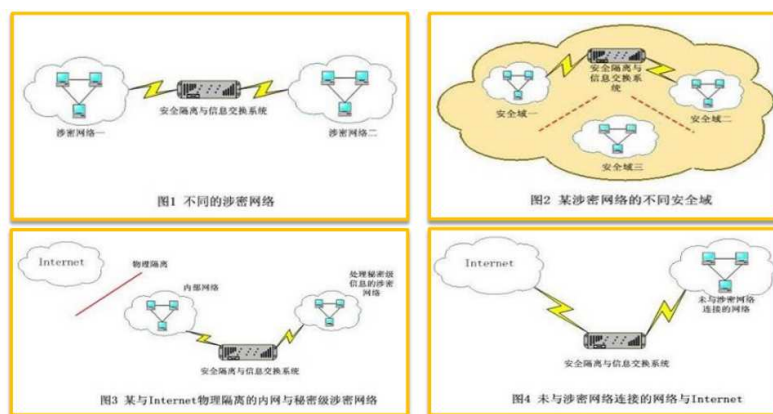


图 9.2: 国家保密局限定的安全隔离网闸使用环境

9.7 NAC 主要功能

- 认证与授权
- 扫描与评估
- 隔离与实施
- 更新与修复

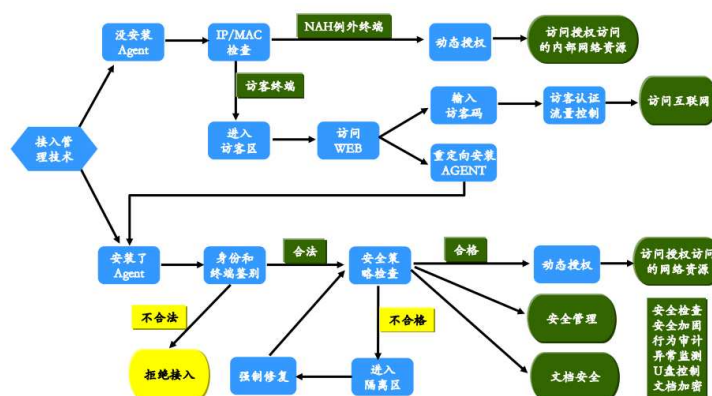


图 9.3: NAC

9.8 网络准入控制基本流程

- 用户终端接入网络，认证前都具有**认证前域**网络权限，包括访问准入控制服务器、DHCP、DNS 等。
- 对用户终端进行身份认证，认证通过后，准入服务器下发网络权限到网络准入设备，允许该用户访问**认证后域**网络。
- 对于一些合法但是不安全的用户，身份认证后，准入服务器下发**隔离域**网络权限到网络准入设备，仅允许该用户访问隔离域网络，用户安全修复后，重新下发认证后域网络权限
- 在隔离域时，用户可以根据需要进行终端代理软件安装，补丁安装，杀毒软件安装、升级等操作
- 非法用户及未认证用户仅允许访问认证前域或隔离域网络资源

第 9 章 重点

1. IDS 和 IPS 的差异
2. 四个图哪个是国家保密局强制要求部署网闸的环境
3. NAC 的工作流程、主要功能

第 10 章 VPN IPSec SSL

10.1 IPSec 协议

IPSec 协议实际上是一个协议包而不是一个单个的协议，主要是下面三个协议

- 认证头 (Authentication Header, AH) : 用于数据完整性认证和数据源认证。
- 封装安全负荷 (Encapsulating Security Payload, ESP) : 提供数据保密性和数据完整性认证，ESP 也包括了防止重放攻击的顺序号。
- Internet 密钥交换协议 (Internet Key Exchange, IKE) : 用于生成和分发在 ESP 和 AH 中使用的密钥，IKE 也对远程系统进行初始认证。

10.1.1 AH 协议

提供了**数据完整性**和数据源认证，即用来保证传输的 IP 报文的来源可信和数据不被篡改，但它并不提供加密功能。

10.1.2 ESP 协议

IPSec 封装安全负荷提供了数据加密功能。ESP 利用对称密钥对 IP 数据 (例如 TCP 包) 进行加密

由于 ESP 除具备 AH 的全部功能外还用于确保数据包的机密性，因此每个 ESP 的 SA 都必须同时定义两套算法：负责保护机密性的加密算法和负责进行身份验证的鉴别算法

10.2 IPSec 封装模式

10.2.1 传输模式

传输模式下，与 AH 协议相比，ESP 协议的完整性验证范围不包括 IP 头，无法保证 IP 头的安全

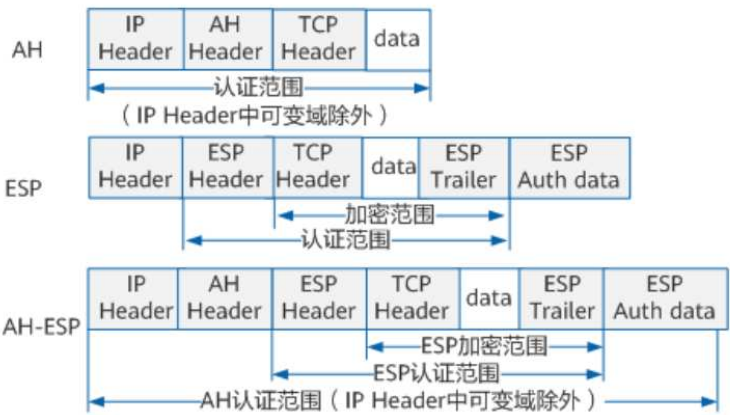


图 10.1: 传输模式

10.2.2 隧道模式

隧道模式下，与 AH 协议相比，ESP 协议的完整性验证范围不包括新 IP 头，无法保证新 IP 头的安全

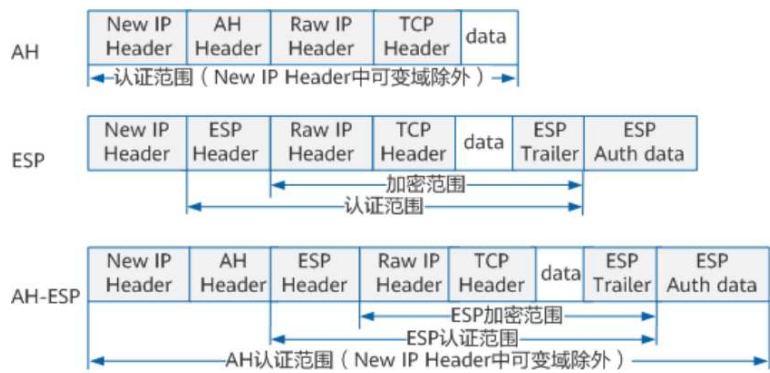


图 10.2: 隧道模式

10.3 VPN 通道的建立方式

- Host 对 Host
 - 该模式要求两边主机都支持 IPsec
 - VPN 网关可支持也可不支持 IPsec
- Host 对 VPN 网关
 - 非安全通道一侧的主机可以不支持 IPsec 但是其 VPN 网关必须支持
 - 安全通道一侧的主机支持 IPsec 但是其 VPN 网关可以不支持
- VPN 对 VPN 网关
 - 该模式不要求主机支持 IPsec
 - 两边的 VPN 网关必须支持 IPsec
- Remote User 对 VPN 网关
 - 该模式不要求同关内主机支持 IPsec

第 10 章 重点

1. VPN 在什么场合下的 VPN 比较多
2. IPSEC 使用的协议
3. 安全隔离（外端机、内端机，中间的隔离系统采用私有协议（规定必须是单向的））
4. VPN 的建立方式，在哪些设备上需要同步支持

参考文献

- [1] Fortinet. *What is an IPS?* URL: <https://www.fortinet.com/cn/resources/cyberglossary/what-is-an-ips>.
- [2] frankx. *CISSP 中提到的两个安全性模型- BLP 模型, Biba 模型*. 2019. URL: <https://zhuanlan.zhihu.com/p/64855340>.
- [3] National Technical Reports Library. *Information Assurance Technical Framework (IATF). Release 3.1*. 2002. URL: <https://ntrl.ntis.gov/NTRL/dashboard/searchResults/titleDetail/ADA606355.xhtml>.
- [4] Mr.E5. 防火墙技术原理分享. 2020. URL: https://blog.csdn.net/weixin_45591980/article/details/108640594.
- [5] Author's Name. "The NIST model for role-based access control". In: *Proceedings of the fifth ACM workshop on Role-based access control*. Year. DOI: 10.1145/344287.344301. URL: <https://dl.acm.org/doi/10.1145/344287.344301>.
- [6] OWASP. *OWASP Top Ten - A01: Broken Access Control*. 2021. URL: https://owasp.org/Top10/A01_2021-Broken_Access_Control/.
- [7] xiejava1018. 网络信息安全之基于时间的安全模型 (PDR 和 PPDR 模型). 2022. URL: <https://blog.csdn.net/fullbug/article/details/124359142>.